UNIT 2 · TOPIC 2.2

Physical Vulnerabilities and Attacks

Quiz

Instructions: This quiz has 18 multiple-choice questions, 1 point each. Circle the letter of the single best answer for each question.

Name: **Date:** **Class:**

1. Which of the following is classified as a physical attack on an organization's assets?

- ○ A. An attacker exploits a SQL injection flaw in a web login form to extract a database.
- ○ B. An unauthorized person follows a badged employee through a secured entrance without scanning their own credential.
- ○ C. An attacker sends a phishing email impersonating the IT help desk to capture employee passwords.
- ○ D. An attacker uses a brute-force script to guess a wireless router password from a parking lot.

2. Which of the following scenarios describes an environmental threat to physical security?

- ○ A. An unauthorized visitor tailgates a researcher through a secured lab door.
- ○ B. A visitor photographs a sensitive document displayed on an unattended monitor.
- ○ C. An employee leaves a workstation unlocked and unattended when stepping away for lunch.
- ○ D. A burst water pipe floods a ground-floor server room, destroying several rack-mounted servers.

3. An attacker retrieves a discarded employee ID card and printed access-control policy from a recycling bin placed outside an office building. Which type of physical attack does this represent?

- ○ A. Dumpster diving
- ○ B. Shoulder surfing
- ○ C. Tailgating
- ○ D. Device theft

4. A physical security assessor at a newly acquired research lab identifies two vulnerabilities: (1) the building's main entrance has no lock and anyone can walk in, and (2) the server room has no cable locks on workstations. In terms of risk impact to data confidentiality, which vulnerability poses the greater threat and why?

- ○ A. Neither poses a significant risk to data confidentiality if all workstations are protected by login passwords.
- ○ B. The missing cable locks, because workstations can be physically removed from the premises with the data still on them.
- ○ C. Both pose an equal risk because each allows unauthorized access to physical assets.
- ○ D. The unlocked entrance, because it enables a threat actor to physically reach any asset in the building, including the server room.

5. A server room at Xtensr Labs is located adjacent to a public corridor and has no environmental sensors installed. A water pipe in the adjacent corridor bursts, flooding the server room before staff are aware of the issue. Which factor best explains how a physical vulnerability enabled the environmental threat to cause destruction?

- ○ A. Lack of network segmentation allowed the flooding to cascade across interconnected systems.
- ○ B. The threat actor used social engineering to locate and burst the pipe at a strategic moment.
- ○ C. Encrypting the servers would have prevented the flood from causing data loss.

○ D. The absence of environmental monitoring meant the flooding was not detected in time to prevent hardware destruction.

6. An attacker uses shoulder surfing to observe a system administrator typing credentials into a privileged management console in a shared open-plan office. Evaluate which asset category is most directly placed at risk by this attack.

○ A. Privileged logical access to any system or data reachable by that administrator's account.

○ B. Encrypted backup tapes stored in an off-site vault.

○ C. Physical hardware in the server room managed by that console.

○ D. Network bandwidth and availability on the internal LAN.

7. A physical security analyst conducting the Xtensr Labs assessment identifies two vulnerabilities: (1) the server room has no badge reader, rated Likelihood: High, Impact: High; and (2) external windows in the server room are unbarred, rated Likelihood: Low, Impact: High. Using a standard likelihood-impact risk matrix, which vulnerability should be prioritized for remediation and on what basis?

○ A. Vulnerability 2, because high impact always takes precedence over likelihood in security risk evaluations.

○ B. Vulnerability 2, because physical barriers such as window bars are more difficult and costly to implement than badge readers, making them higher priority.

○ C. Both should be treated as equal priority because both carry a High impact rating.

○ D. Vulnerability 1, because it occupies the highest risk tier on the matrix, both likelihood and impact are high, yielding a Critical composite score.

8. An analyst evaluates the risk of device theft in a lab where researchers routinely leave laptops unattended and unlocked. She rates the likelihood as High. Because all research data is backed up daily to an off-site server, she rates the impact as Medium. Which conclusion best reflects proper composite risk impact evaluation?

○ A. The risk is Medium-High, because a High likelihood combined with a Medium impact produces a mid-tier composite score, and residual impacts such as device replacement cost and brief data unavailability remain.

○ B. The risk is Low because daily backups effectively reduce the overall impact to near zero.

○ C. The risk is Critical because device theft would expose sensitive research data regardless of backups.

○ D. The risk is High because likelihood alone is the primary driver of risk score when impact cannot be fully quantified.

9. A physical security team uses an AI-assisted tool to evaluate risk likelihood scores for the newly acquired Xtensr Labs building. The tool flags an unmonitored loading dock as "Low likelihood" based on historical incident logs from the previous occupant. As the lead analyst, which factor most critically limits the reliability of this AI-generated likelihood score?

○ A. AI risk evaluation tools cannot reliably process historical incident datasets larger than a few hundred records.

○ B. Loading docks are universally low-risk entry points in physical security frameworks, so the AI classification is likely accurate.

○ C. Likelihood scores must always be determined manually; AI tools have no valid role in physical security risk analysis.

○ D. The historical data reflects the prior organization's threat environment and operational context, which may not apply to Xtensr Labs' different profile and threat actors.

10. Which of the following fields is always included in a risk register entry for a physical vulnerability?

○ A. The name of the hardware vendor whose equipment is affected.

○ B. A description of the vulnerability, its likelihood of exploitation, and its potential impact.

- ○ C. The complete source code of any software associated with the vulnerability.
- ○ D. A full list of all employees who regularly use the affected physical space.

11. A security analyst is documenting physical attacks observed at Xtensr Labs. A staff member reports that a visitor stood directly behind her at a shared kiosk and watched her enter her PIN. Which attack is the analyst documenting?

- ○ A. Shoulder surfing
- ○ B. Tailgating
- ○ C. Piggybacking
- ○ D. Dumpster diving

12. Which of the following most accurately describes the physical attack an analyst would label as dumpster diving when writing an incident report?

- ○ A. An attacker cuts through a server room wall to gain access without triggering door-based alarms.
- ○ B. An attacker searches discarded materials, printed documents, decommissioned hard drives, or access badges, for information useful in compromising security.
- ○ C. An attacker gains entry to a restricted floor by following an authorized employee through a badge-controlled door.
- ○ D. An attacker installs a hardware keylogger on a workstation while posing as a maintenance worker.

13. A security team at Xtensr Labs is documenting the risk posed by a server room with no door lock, located directly off a public corridor. Which field in a standard risk register entry specifically captures the mechanism by which this vulnerability can lead to data loss or disruption?

- ○ A. Asset value
- ○ B. Threat description
- ○ C. Risk owner
- ○ D. Control status

14. When documenting the risk of unauthorized tailgating into a secured research lab, which asset category is most directly placed at risk according to the threat pathway described?

- ○ A. Software licenses and cloud subscriptions managed by the organization.
- ○ B. Employee payroll records stored in a third-party cloud HR platform.
- ○ C. Firewall access control list configurations stored on network appliances.
- ○ D. Physical assets such as servers, workstations, removable media, and printed documents within the lab.

15. A security analyst is completing a risk register entry documenting the threat that power surges from ageing building infrastructure could destroy research workstations at Xtensr Labs. Which field in the entry specifically captures how probable this event is to occur within a defined timeframe?

- ○ A. Impact rating
- ○ B. Likelihood rating
- ○ C. Residual risk
- ○ D. Risk treatment

16. After completing the physical vulnerability assessment at Xtensr Labs, the security team presents findings to leadership. Leadership acknowledges an unmonitored loading dock as a documented vulnerability but formally decides, due to budget constraints, not to install a badge reader or camera. Which risk register field must be updated to correctly reflect this decision and maintain an auditable record?

- ○ A. Vulnerability description, to note that leadership reviewed it.
- ○ B. Likelihood rating, to lower it now that leadership has acknowledged the risk.
- ○ C. Risk treatment decision, with the chosen response (risk acceptance) and a record of formal leadership sign-off and rationale.
- ○ D. Asset value, to reflect the reduced priority leadership has assigned to the affected area.

17. A security professional uses an AI-assisted tool to auto-populate a risk register for physical vulnerabilities at the newly acquired Xtensr Labs facility. The tool generates entries for tailgating, dumpster diving, and device theft, but assigns identical likelihood scores (Medium) to all three threats. What is the most important action the analyst must take before submitting the report to leadership?

- ○ A. Replace all AI-generated entries with manually written descriptions to comply with physical security documentation standards.
- ○ B. Accept the AI-generated scores without modification, because AI tools are trained on large industry datasets and produce more reliable scores than individual analyst judgment.
- ○ C. Validate and, where necessary, adjust each AI-generated likelihood score using site-specific evidence such as access logs, physical inspection notes, and incident history from comparable facilities.
- ○ D. Submit the report with a disclosure statement noting that AI was used, which satisfies the organization's audit and compliance requirements.

18. During the Xtensr Labs physical vulnerability assessment, an analyst documents two risks in the register: Risk A, a prop door in a secure corridor (Likelihood: High, Impact: Low); Risk B, proximity of the server room to an external wall with no blast or intrusion protection (Likelihood: Low, Impact: High). When recommending risk response priorities in the documentation, which principle should guide the ordering?

- ○ A. Risk B should always be prioritized because catastrophic but infrequent events pose inherently greater danger than frequent low-impact events.
- ○ B. Both risks should be evaluated using a composite risk score (likelihood × impact), and their treatment order should be determined by that score in conjunction with the organization's documented risk appetite and tolerance thresholds.
- ○ C. Risk A should be prioritized because frequent low-impact events can accumulate over time and cause aggregate harm greater than a single high-impact event.
- ○ D. Neither risk requires prioritized documentation since neither simultaneously exhibits high likelihood and high impact.